# Inventario y clasificación de datos personales

## Hito 1 Plataforma de comercio electrónico NortiShop

**Asignatura:** Seguridad y Protección de Datos

**Grupo:** _____

**Integrantes:** Ariel Van Kilsdonk y Carlos Orellana

**Caso:** NortiShop

**Fecha:** 5 de octubre de 2026

# Índice

1 Introducción 2

2 Inventario de datos personales 3

3 Mapa de flujos de datos 5

4 Clasificación por sensibilidad 6

5 Finalidad y base de licitud 8

6 Conclusiones 9

7 Referencias 9

8 Anexos 10

La numeración comienza después de la portada.

# 1 Introducción

NortiShop es una tienda chilena en línea de tecnología y accesorios. La plataforma gestiona cuentas, catálogo, carrito, checkout, pedidos, direcciones, facturación, pagos mediante una pasarela externa, NortiPuntos, marketing y reseñas. El inventario muestra que la operación depende de identificadores, contacto, ubicación, actividad transaccional y datos que permiten perfilar hábitos de consumo.

Los actores principales son el cliente registrado y el invitado; el administrador que gestiona catálogo y pedidos; el equipo de marketing; la pasarela de pago; y los encargados externos de correo, soporte y despacho. NortiShop actúa como responsable cuando decide la finalidad y los medios. Los proveedores operan como encargados o terceros según el contrato y el grado de decisión que conserven.

La conclusión principal es que los controles más urgentes son limitar los datos entregados a terceros, impedir que el comercio almacene el número completo de tarjeta, cifrar identificadores y ubicaciones, proteger la integridad de pagos y NortiPuntos, y conservar evidencia verificable del consentimiento. Esta matriz es académica y debe validarse jurídicamente antes de una puesta en producción.

# 2 Inventario de datos personales

Los plazos son una política propuesta de minimización. Deben ajustarse a obligaciones tributarias, de consumo, prescripción, contratos con proveedores y eventuales litigios. Al vencer el plazo, NortiShop debe suprimir o anonimizar de manera irreversible.

| Categoría | Dato específico | Fuente | Almacenamiento | Finalidad | Base de licitud | Con quién se comparte | Conservación |
|---|---|---|---|---|---|---|---|
| Identificación | Nombre completo | Registro o checkout | customers / orders | Identificar comprador y destinatario | Consentimiento informado; desde 01-12-2026, contrato (art. 13 c) | Pasarela y transportista, solo si corresponde | Cuenta activa + 12 meses; en pedidos, plazo legal aplicable |
| Identificación | RUT | Facturación | billing_profiles / invoices | Emitir documento tributario y validar identidad | Consentimiento o habilitación legal; futura obligación legal/contrato | Proveedor de facturación y autoridad competente | 6 años propuestos, sujeto a matriz tributaria |
| Contacto | Correo electrónico | Registro o checkout | customers / orders | Confirmaciones, recuperación y soporte | Consentimiento; futura ejecución contractual | Proveedor de correo transaccional | Cuenta activa + 12 meses; pedido según obligación |
| Contacto | Teléfono | Checkout | customers / shipments | Coordinar entrega y resolver incidencias | Consentimiento; futura ejecución contractual | Transportista | Hasta 12 meses tras entrega, salvo reclamo |
| Autenticación | Hash de contraseña | Registro | credentials | Autenticar cuenta | Consentimiento; futura ejecución contractual | No se comparte | Mientras la cuenta permanezca activa |
| Ubicación | Dirección de despacho | Checkout o libreta | addresses / orders | Entregar productos | Consentimiento; futura ejecución contractual | Transportista | Pedido + 12 meses; guardada hasta retiro del titular |
| Ubicación | Coordenada aproximada de entrega | Servicio logístico | shipments | Optimizar y comprobar entrega | Consentimiento específico; futura ejecución contractual | Transportista | 90 días después de la entrega |
| Facturación | Dirección de facturación | Checkout | billing_profiles / invoices | Emitir documento tributario | Consentimiento o ley; futura obligación legal/contrato | Proveedor de facturación | 6 años propuestos, sujeto a matriz tributaria |
| Transaccional | Historial de pedidos | Compra | orders / order_items | Gestionar compra, garantía y soporte | Consentimiento; futura ejecución contractual | Pasarela, logística y soporte por necesidad | 6 años propuestos para respaldo comercial/tributario |
| Comportamiento | Carrito y productos vistos | Navegación | carts / analytics | Mantener carrito y mejorar navegación | Consentimiento diferenciado para analítica | Proveedor analítico, si se habilita | 30 días carrito; 13 meses analítica agregada |
| Pago | Token del medio de pago | Pasarela externa | payment_methods | Facilitar pago guardado | Consentimiento separado; futura ejecución contractual | Pasarela de pago | Hasta retiro o 12 meses de inactividad |
| Pago | Marca y últimos 4 | Pasarela externa | payment_methods / payments | Reconocer medio y conciliar | Consentimiento; futura ejecución contractual | Soporte y pasarela | Igual al token o al registro de pago |
| Pago | Monto, estado y autorización | Pasarela externa | payments | Confirmar y conciliar transacción | Consentimiento/ley; futura ejecución contractual | Pasarela y finanzas | 6 años propuestos, sujeto a obligación aplicable |
| Seguridad | IP, dispositivo y eventos de sesión | Aplicación | security_logs | Prevenir abuso e investigar incidentes | Consentimiento informado; futuro interés legítimo art. 13 d | Proveedor de monitoreo bajo contrato | 12 meses, ampliable si existe incidente |

| Categoría | Dato específico | Fuente | Almacenamiento | Finalidad | Base de licitud | Con quién se comparte | Conservación |
|---|---|---|---|---|---|---|---|
| Fidelización | Saldo y movimientos NortiPuntos | Compras y canjes | loyalty_ledger | Otorgar y canjear beneficios | Consentimiento; futura ejecución contractual | No se comparte salvo soporte | Cuenta activa + 24 meses |
| Marketing | Consentimiento, versión y fecha | Formulario separado | marketing_consents | Acreditar preferencia y gestionar baja | Consentimiento expreso y revocable | Proveedor de mailing | Vigencia + 3 años como evidencia de revocación |
| Marketing | Aperturas y clics | Boletín | marketing_events | Medir campaña y segmentar | Consentimiento específico de analítica | Proveedor de mailing | 13 meses y luego agregación |
| Contenido | Alias y reseña | Publicación del cliente | reviews | Informar a otros compradores | Consentimiento y acción manifiesta de publicación | Público general | Hasta retiro, moderación o fin del producto |
| Soporte | Mensajes, adjuntos y motivo | Canal de soporte | support_tickets | Resolver solicitud o reclamo | Consentimiento; futura ejecución contractual o defensa | Proveedor de mesa de ayuda | 24 meses tras cierre; más si hay disputa |
| Logística | Número y eventos de seguimiento | Transportista | shipments | Informar estado de entrega | Consentimiento; futura ejecución contractual | Cliente, soporte y transportista | 12 meses tras entrega |

# 3 Mapa de flujos de datos

Los cuatro flujos cubren los recorridos que concentran mayor volumen o riesgo. La transformación describe el punto donde se minimiza, cifra, deriva o tokeniza la información.

| Flujo | Origen | Actor o sistema | Destino | Datos | Transformación y control | Riesgos CIA |
|---|---|---|---|---|---|---|
| F1 Registro y acceso | Cliente | Web/app NortiShop | Servicio de identidad y BD | Nombre, correo, contraseña | Validación; contraseña a scrypt; correo cifrado e indexado | C: filtración de cuenta; I: cambio de correo; D: caída del acceso |
| F2 Checkout y pago | Cliente/invitado | Checkout NortiShop | Pasarela y BD de pedidos | Identidad, contacto, monto, medio de pago | TLS; PAN directo a pasarela; retorna token y autorización | C: exposición de pago; I: alterar monto/estado; D: impedir compra |
| F3 Despacho | Pedido confirmado | Módulo logístico | Transportista y cliente | Nombre, teléfono, dirección, seguimiento | Cifrado en reposo; minimización; acceso temporal | C: ubicación; I: cambiar destino; D: perder trazabilidad |
| F4 Marketing | Cliente con opt in | Gestor de consentimientos | Proveedor de mailing | Correo, preferencia, eventos | Separar marketing de mensajes transaccionales; baja sincronizada | C: perfil conductual; I: ignorar baja; D: impedir ejercer revocación |

## 3.1 Detalle del checkout y pago

El navegador envía identidad, contacto, dirección y contenido del carro a NortiShop mediante TLS. El formulario de tarjeta debe quedar alojado por la pasarela o transmitir el PAN directamente a ella, sin pasar por registros ni bases del comercio. La pasarela devuelve un token, el resultado y el código de autorización. NortiShop vincula esos valores al pedido y solo marca el pago como aprobado después de verificar la respuesta firmada o autenticada del proveedor.

Este diseño reduce la exposición del PAN, pero el token y la respuesta de pago siguen siendo activos críticos. El servicio debe validar monto, moneda, identificador de pedido y estado; rechazar repeticiones; mantener trazabilidad; y separar permisos de soporte, administración y conciliación.

# 4 Clasificación por sensibilidad

La clasificación combina la definición vigente de dato personal y sensible con las categorías destacadas en las clases. Un dato puede no ser sensible por naturaleza y aun así requerir protección alta por su persistencia, capacidad de correlación o impacto.

| Dato o conjunto | Clasificación | Justificación |
|---|---|---|
| Nombre completo | Personal | Identifica directamente a una persona natural. |
| RUT | Personal de alta criticidad | Identificador nacional persistente; facilita correlación y suplantación. |
| Correo y teléfono | Personal | Permiten identificar y contactar al titular; elevan riesgo de phishing. |
| Hash de contraseña | Personal de autenticación | Está asociado a la cuenta y protege el acceso; no debe ser reversible. |
| Direcciones | Personal | Vinculan al titular con un domicilio o lugar de entrega. |
| Coordenada de entrega | Categoría especial: geolocalización | La clase identifica movilidad/geolocalización como dato que requiere protección reforzada. |
| Historial de pedidos | Sensible por hábitos | Puede revelar hábitos personales y preferencias; la Ley 19.628 incluye hábitos en datos sensibles. |
| Carrito y vistas | Sensible por perfilamiento | La secuencia de navegación permite inferir intereses y hábitos de consumo. |
| Token, marca y últimos 4 | Personal financiero | Se vinculan con medios de pago y deben tratarse como información de alta criticidad. |
| Monto, estado y autorización | Sensible socioeconómico | Revela comportamiento económico; la Ley 21.719 incorpora situación socioeconómica. |
| IP, dispositivo y sesión | Personal | Puede individualizar indirectamente a un usuario y su actividad. |
| NortiPuntos | Personal transaccional | Refleja compras y beneficios asociados a una cuenta. |
| Consentimiento de marketing | Personal | Registra una decisión atribuida al titular y debe conservar evidencia íntegra. |
| Aperturas y clics | Sensible por hábitos | Perfila conducta e intereses respecto de campañas y productos. |
| Alias y reseña | Personal publicado | Puede identificar al autor; la publicación no elimina obligaciones de finalidad y seguridad. |
| Ticket y adjuntos | Variable; potencialmente sensible | El contenido libre puede incluir identidad, pago u otros datos no previstos. |
| Seguimiento de entrega | Personal de ubicación | Vincula a una persona con eventos, horarios y destino de entrega. |

## 4.1 Criterios aplicados

- Dato personal: identifica o hace identificable al cliente, directa o indirectamente.
- Dato sensible: la Ley 19.628 vigente (art. 2 g) incluye los hábitos personales. La definición de la Ley 21.719, vigente desde el 1 de diciembre de 2026, ya no nombra los hábitos y sí explicita la situación socioeconómica; por eso, desde esa fecha, historial, carrito y clics se tratan como datos personales de alta criticidad por perfilamiento, con los mismos controles.
- Categoría especial: en este caso aparece geolocalización. NortiShop no necesita biometría ni datos de menores para su finalidad ordinaria, por lo que no debe recolectarlos por defecto.

# 5 Finalidad y base de licitud

Al 5 de octubre de 2026 sigue vigente la versión actual de la Ley 19.628. Su artículo 4 exige autorización legal o consentimiento expreso e informado. La Ley 21.719 entra en vigencia el 1 de diciembre de 2026 y añadirá, entre otras fuentes, obligación legal, contrato, interés legítimo y defensa de derechos en su nuevo artículo 13. El diseño registra ambas capas para evitar confundir una fuente futura con la base vigente.

| Flujo | Finalidad específica | Base de licitud y justificación | Condición de implementación |
|---|---|---|---|
| Registro de cuenta | Crear credenciales y perfil solicitado | Ley 19.628 art. 4: consentimiento expreso e informado. Desde 01-12-2026, Ley 21.719 art. 13 c: contrato o medidas precontractuales. | Aviso por capas; aceptación separada de marketing; prueba de versión y fecha. |
| Checkout y pago | Celebrar y ejecutar la compra | Consentimiento vigente bajo art. 4; futura fuente contractual del art. 13 c. | Enviar PAN directamente a pasarela; NortiShop recibe token, estado y autorización. |
| Facturación | Emitir y conservar documentación tributaria | Autorización u obligación legal; futura fuente del art. 13 b. | Separar archivo tributario del perfil comercial y restringir acceso. |
| Despacho | Entregar el pedido y notificar incidencias | Consentimiento para comunicación; futura ejecución contractual art. 13 c. | Compartir al transportista solo nombre, contacto, dirección y referencia necesaria. |
| NortiPuntos | Calcular, mostrar y canjear beneficios | Consentimiento al programa; futura ejecución contractual art. 13 c. | Libro de movimientos auditable y baja sin afectar obligaciones pendientes. |
| Boletín y perfilamiento | Enviar ofertas y medir campañas | Consentimiento específico, informado y revocable; no se mezcla con la compra. | La revocación se propaga al proveedor y cesa el seguimiento. |
| Logs de seguridad | Prevenir fraude e investigar incidentes | Consentimiento informado en el régimen actual; futuro interés legítimo art. 13 d, con ponderación documentada. | Minimización, 12 meses, acceso restringido y exclusión de contenidos innecesarios. |
| Soporte y reclamos | Resolver consultas, garantías o disputas | Consentimiento/relación solicitada; desde 01-12-2026 contrato o defensa de derechos, art. 13 c y e. | Advertir sobre adjuntos, aplicar retención y cifrar contenido. |

## 5.1 Reglas transversales

- Finalidad: no reutilizar datos de compra para marketing sin consentimiento separado.
- Proporcionalidad: no exigir fecha de nacimiento, biometría o geolocalización continua para vender y despachar productos.
- Transparencia: informar categorías, proveedores, plazos, transferencias y medios para ejercer derechos.
- Responsabilidad: conservar evidencia de controles, contratos con encargados, revisiones de acceso y pruebas de recuperación.

# 6 Conclusiones

Los datos más críticos son el RUT, las direcciones, el historial de compra, las referencias de pago y los registros que permiten perfilar al cliente. Su combinación produce más riesgo que cada campo aislado. El pago concentra exposición a terceros y exige tokenización; el despacho requiere minimización y acceso temporal; marketing exige una decisión separada y revocable.

Los riesgos CIA más relevantes son la filtración masiva de identidades y ubicaciones, la manipulación de montos o estados de pago, el fraude sobre NortiPuntos y la indisponibilidad del checkout o de los mecanismos para gestionar la cuenta. Cifrado, hashing y tokenización reducen el impacto, pero deben acompañarse de RBAC, MFA administrativo, auditoría, respaldo, monitoreo y gestión de incidentes.

Quedan abiertas cuatro decisiones: el plazo legal exacto de cada documento comercial y tributario; la ubicación y subencargados de pasarela, correo y analítica; la ponderación del interés legítimo para seguridad desde diciembre de 2026; y si NortiShop permitirá cuentas de menores. Estas preguntas deben resolverse antes de aprobar la política definitiva.

# 7 Referencias


1. Biblioteca del Congreso Nacional. Ley 19.628 sobre protección de la vida privada, versión vigente entre 09-05-2023 y 30-11-2026. Arts. 1, 4, 7, 9 y 11. https://www.bcn.cl/leychile/Navegar?idNorma=141599&idVersion=2023-05-09
2. Biblioteca del Congreso Nacional. Ley 21.719 que regula la protección y el tratamiento de los datos personales. Publicada 13-12-2024; vigencia 01-12-2026. Nuevo art. 13 y arts. 14 bis a 14 sexies. https://www.bcn.cl/leychile/navegar?idNorma=1209272
3. Material del curso. CLASE 1 PROTECCION DATOS PERSONALES.pdf. Clasificación, consentimiento, finalidad, derechos y obligaciones.
4. Material del curso. Seguridad y Proteccion de Datos - PR - 01.pptx. Triángulo CIA y proyecto integrador.
5. Material del curso. Seguridad y Proteccion de Datos - PR - 02.pptx. Cifrado, hashing, tokenización y gestión de llaves.
6. NIST. Special Publication 800-38D. Galois Counter Mode and GMAC. https://csrc.nist.gov/pubs/sp/800/38/d/final
7. RFC Editor. RFC 7914, The scrypt Password Based Key Derivation Function. https://www.rfc-editor.org/info/rfc7914/
8. PCI Security Standards Council. Tokenization Guidelines. https://www.pcisecuritystandards.org/documents/Tokenization_Guidelines_Info_Supplement.pdf

# 8 Anexos

## Anexo A Actividad 1 Mapeo de actores datos y riesgos CIA

| Actor | Dato | CIA | Justificación |
|---|---|---|---|
| Cliente registrado | Nombre completo | Confidencialidad | Una consulta o exportación sin control identifica directamente al cliente. |
| Cliente registrado | RUT | Confidencialidad | Es un identificador persistente y facilita suplantación o cruces de bases. |
| Cliente registrado | Correo electrónico | Confidencialidad | Una filtración habilita phishing y vincula la cuenta con una persona. |
| Cliente registrado | Teléfono | Confidencialidad | Puede utilizarse para fraude, contacto no solicitado o recuperación abusiva de cuenta. |
| Cliente registrado | Contraseña | Confidencialidad | Si se almacena de forma reversible o con hash débil, compromete esta y otras cuentas. |
| Cliente registrado | Dirección de despacho | Confidencialidad | Revela domicilio o ubicación habitual y expone al titular a riesgos físicos. |
| Cliente registrado | Dirección y RUT de facturación | Confidencialidad | Combina identidad, domicilio e información asociada a una compra. |
| Cliente registrado | Historial de pedidos | Confidencialidad | Permite inferir hábitos, intereses y capacidad de consumo. |
| Cliente registrado | Saldo y movimientos NortiPuntos | Integridad | Una alteración concede descuentos indebidos o priva al cliente de beneficios. |
| Cliente registrado | Reseña y alias público | Integridad | Cambios no autorizados atribuirían opiniones falsas al cliente. |
| Cliente invitado | Nombre y correo de contacto | Confidencialidad | El dato se usa sin una cuenta permanente y no debe quedar accesible fuera del pedido. |
| Cliente invitado | Dirección de despacho | Confidencialidad | La exposición permite localizar al destinatario y conocer su compra. |
| Cliente o invitado | Contenido del carrito | Confidencialidad | Puede revelar preferencias antes de que exista una compra confirmada. |
| Cliente o invitado | Dirección IP y datos de sesión | Confidencialidad | Permiten rastrear actividad y vincular eventos con una persona o dispositivo. |
| Pasarela de pago | Token del medio de pago | Confidencialidad | Aunque sustituye el PAN, un token reutilizable puede facilitar cargos si se roba. |
| Pasarela de pago | Marca y últimos cuatro dígitos | Confidencialidad | Son datos de pago parciales que aumentan el riesgo al combinarse con otros datos. |
| Pasarela de pago | Monto, estado y código de autorización | Integridad | Una modificación puede marcar como pagado un pedido rechazado o alterar el monto. |

| Actor | Dato | CIA | Justificación |
|---|---|---|---|
| Administrador | Estado y detalle del pedido | Integridad | Cambios indebidos afectan cobro, inventario, despacho y trazabilidad. |
| Administrador | Exportación de clientes y pedidos | Confidencialidad | Un privilegio excesivo permite extraer datos personales a gran escala. |
| Equipo de marketing | Consentimiento y preferencias | Integridad | Debe probarse la decisión vigente del titular y respetarse la revocación. |
| Equipo de marketing | Aperturas y clics del boletín | Confidencialidad | El seguimiento perfila intereses y comportamiento del destinatario. |
| Transportista | Nombre, teléfono, dirección y seguimiento | Confidencialidad | La información debe limitarse al despacho y al período estrictamente necesario. |
| Soporte al cliente | Ticket, mensajes y adjuntos | Confidencialidad | El usuario puede incluir identificadores, comprobantes o información de pago. |
| Plataforma NortiShop | Catálogo, carrito y checkout | Disponibilidad | Una caída impide comprar, consultar pedidos o ejercer acciones sobre la cuenta. |

## Anexo B Actividad 2 Matriz de cifrado

| Campo | Necesidad | Elección | Criterio | Implementación | Evidencia |
|---|---|---|---|---|---|
| Contraseña | Validar sin recuperar el original | Hashing scrypt con sal | Función lenta y resistente a hardware; sal única evita tablas precalculadas | hashlib.scrypt; N=2^17 (mínimo OWASP), r=8, p=1; comparación constante | Prueba acepta clave correcta y rechaza una distinta |
| RUT | Recuperar para facturación o atención autorizada | AES-256-GCM | Reversibilidad, confidencialidad e integridad autenticada | Nonce aleatorio de 96 bits y contexto customer:rut | Ciphertext no contiene el RUT y round trip exitoso |
| Correo | Contactar y buscar una cuenta | AES-256-GCM + índice ciego | Separa recuperación de búsqueda exacta sin guardar el valor legible | HMAC-SHA-256 normalizado para índice; AES-GCM para valor | Dos formatos equivalentes producen el mismo índice |
| Teléfono | Usar en despacho y soporte | AES-256-GCM | Debe recuperarse por roles autorizados y detectar manipulación | Contexto customer:phone; llave fuera del código | Descifrado solo con llave y contexto correctos |
| Dirección de despacho | Entregar el pedido | AES-256-GCM | Dato de ubicación recuperable solo durante el flujo logístico | Cifrado por campo; acceso temporal del transportista | Prueba: ciphertext sin texto claro y round trip exitoso |
| Dirección de facturación | Emitir documento tributario | AES-256-GCM | Requiere recuperación y conservación controlada | Contexto order:billing-address y política de retención | Round trip con contexto order:billing-address |
| PAN de tarjeta | Autorizar pago sin almacenarlo en el comercio | Tokenización de pasarela | Reduce el dato de tarjeta presente en NortiShop | Base principal guarda token, marca y últimos 4; PAN queda en vault | Registro del comercio no contiene PAN |
| Token de pago | Permitir cobros autorizados | Cifrado AES-GCM y control de acceso | El token puede conservar valor transaccional aunque no revele el PAN | Token cifrado en reposo (contexto payment:token); uso restringido al servicio de pagos | Registro del comercio no contiene el token legible |

| Campo | Necesidad | Elección | Criterio | Implementación | Evidencia |
|---|---|---|---|---|---|
| Código de autorización | Conciliar pago y pedido | AES-256-GCM | Debe mantenerse confidencial e íntegro para resolver disputas | Contexto payment:authorization; auditoría de cambios | Alterar ciphertext provoca fallo de autenticación |
| Consentimiento de marketing | Acreditar alta, alcance y revocación | HMAC de registro + log inmutable | Predomina integridad y no repudio, no la recuperación secreta | Firma HMAC del evento con fecha, versión y canal | Prueba: alterar o borrar un evento rompe la cadena HMAC |
| Saldo NortiPuntos | Evitar aumentos o descuentos fraudulentos | HMAC + transacciones de base de datos | El control debe detectar manipulación y preservar consistencia | Libro de movimientos encadenado con HMAC; saldo derivado, nunca editado | Prueba: 500 − 200 = 300; manipular un movimiento bloquea el saldo |
| Llaves de datos e índice | Mantener secretos fuera del repositorio | KMS o gestor de secretos | Separación de llaves y datos, rotación y mínimo privilegio | Variables de entorno solo en proceso; .env ignorado | Escaneo de repositorio: 0 secretos asignados |

## Anexo C Evidencia de la implementación

La carpeta Actividad_2/codigo contiene el código, las pruebas y evidencia_funcionamiento.txt. La ejecución del 5 de octubre de 2026 completó cinco pruebas sin errores; la revisión del 29 de octubre amplió la batería a diez pruebas, todas aprobadas. El RUT no aparece en el ciphertext; la contraseña incorrecta se rechaza; la base del comercio no contiene el PAN; y el escaneo no encontró llaves asignadas.